LAPORAN AUDIT DEFENSIVE BACKEND, QA & KEAMANAN DIGIQ (REVISI BUKTI MENTAH)

Tanggal Audit: 29 Oktober 2026

Auditor: Principal Backend Engineer, QA Lead & Security Auditor

Target Repository: `C:\Users\Administrator\Documents\digiq`

Host: Windows Server / Windows Host (Local)

Public Ingress: Cloudflare Zero Trust Tunnel (`https://enikzrad.web.id`)

Backend BaaS: Supabase Cloud (`https://iqxoofrhhrqkgehuvrlb.supabase.co`)

Status Kesiapan Produksi: **BELUM SIAP PRODUKSI (NOT YET PRODUCTION-READY)**

(Alasan: Migrasi database `supabase/006_username_and_registration_hardening.sql` belum dieksekusi di database Supabase live. Sebelum migrasi ini dijalankan, kolom `username` dan RPC `check_username_available` belum ada di live DB).

PENJELASAN TEKNIS: MENGAPA CEK PORT 9000 & CLOUDFLARED SEBELUMNYA EXIT CODE 1

Pada sesi audit sebelumnya, perintah pemeriksaan port 9000 dan pencarian konfigurasi cloudflared menghasilkan `Exited with code 1`. Berikut penyebab teknis pastinya:

1. **`netstat -ano | findstr :9000` (Exit code 1):**

Perintah Windows `findstr` mengembalikan exit code 1 jika string pencarian **tidak ditemukan**. Pada saat pemeriksaan awal dilakukan, skrip `spa_server.py` belum berjalan sebagai proses latar belakang (*daemon*), sehingga port 9000 belum terbuka dan `findstr` menghasilkan code 1.

2. **`Get-NetTCPConnection -LocalPort 9000` (Exit code 1):**

Cmdlet PowerShell `Get-NetTCPConnection` melemparkan exception terminating (`No matching MSFT_NetTCPConnection objects found`) dengan exit code 1 ketika tidak ada proses yang sedang mendengarkan (*listening*) pada port tersebut.

3. **Pencarian `config.yml` Cloudflared (Exit code 1):**

Pencarian file lokal `config.yml` gagal karena Cloudflare Tunnel diinstalasi sebagai **Remote-Managed Tunnel (Zero Trust Dashboard)**. Layanan `cloudflared.exe` dijalankan langsung menggunakan parameter `--token-file C:\ProgramData\cloudflared\token`, bukan file konfigurasi lokal statis.

Verifikasi Ulang Setelah `spa_server.py` Dijalankan:

Saat `spa_server.py` dijalankan di latar belakang (PID: 14488), kedua perintah berhasil dengan **Exit Code 0**:

```
PS C:\Users\Administrator\Documents\digiq> netstat -ano | findstr :9000
  TCP    0.0.0.0:9000           0.0.0.0:0              LISTENING       14488

PS C:\Users\Administrator\Documents\digiq> Get-NetTCPConnection -LocalPort 9000 | Select-Object LocalAddress,
LocalPort, State, OwningProcess
LocalAddress LocalPort  State OwningProcess
------------ ---------  ----- -------------
0.0.0.0           9000 Listen         14488
```

Dan pembuktian target Cloudflare Tunnel dari layanan Windows:

```
PS C:\Users\Administrator\Documents\digiq> (Get-CimInstance win32_service -Filter "Name = 'cloudflared'").PathName
"C:\Program Files (x86)\cloudflared\cloudflared.exe" tunnel run --token-file C:\ProgramData\cloudflared\token
```

BAGIAN 1: VERIFIED (LOLOS PENGUJIAN DENGAN BUKTI MENTAH)

Seluruh item pada bagian ini **telah dieksekusi secara nyata** dalam sesi ini dan disertai log/output mentah:

1.1 Ingress Cloudflare Tunnel Menjangkau Localhost Port 9000

Panggilan HTTP riil dari domain publik `https://enikzrad.web.id/health` berhasil diteruskan oleh `cloudflared` ke `spa_server.py`:

```
Tunnel Ingress Status: 200 OK
Server Header: cloudflare
CF-Ray: a51c65d27ebefe8b-SIN
Content-Type: application/json; charset=utf-8
Body: {"status":"ok","server":"DigiQ-SPA-Windows","port":9000}
```

1.2 Path Traversal Protection (HTTP 403 Forbidden)

Pengujian injeksi path traversal (`/../secret` dan `/../build/web/index.html`) terhadap `spa_server.py` membuktikan penolakan akses:

```
=== Request: GET /../secret ===
Status: 403 Forbidden
Headers:
  Server: DigiQ-SPA-Server/1.0 Python/3.9.0
  Content-Type: text/plain; charset=utf-8
  Content-Length: 14
  X-Content-Type-Options: nosniff
  X-Frame-Options: SAMEORIGIN
  Referrer-Policy: strict-origin-when-cross-origin
  Content-Security-Policy: default-src 'self' 'unsafe-inline' 'unsafe-eval' https: wss: data: blob:;
Body: b'403 Forbidden\n'

=== Request: GET /../build/web/index.html ===
```

```
Status: 403 Forbidden
Body: b'403 Forbidden\n'
```

1.3 Security Headers & SPA Routing Fallback

Pemeriksaan header keamanan pada response root `/`:

```
=== Request: GET / ===
Status: 200 OK
Headers:
  Content-Type: text/html; charset=utf-8
  Cache-Control: no-cache, no-store, must-revalidate
  X-Content-Type-Options: nosniff
  X-Frame-Options: SAMEORIGIN
  Referrer-Policy: strict-origin-when-cross-origin
  Content-Security-Policy: default-src 'self' 'unsafe-inline' 'unsafe-eval' https: wss: data: blob:;
```

1.4 Kompresi Gzip & Brotli

Pengujian membuktikan bahwa `spa_server.py` lokal sengaja mengirimkan byte tanpa kompresi ganda untuk menghemat beban CPU host Windows, sementara Cloudflare Edge secara otomatis mengompresi payload menggunakan algoritma Brotli (`Content-Encoding: br`) saat dikirim ke pengguna:

```
Cloudflare Status: 200 OK
Content-Encoding: br
CF-Ray: a51c66318bea5833-SIN
Server: cloudflare
```

1.5 Secrets Scan Riwayat Git (`git log -p -S`)

Pemindaian riwayat komit Git membuktikan tidak ada kebocoran kunci rahasia (`service_role`, `sbp_`, password, `SECRET_KEY`, atau `DATABASE_URL`):

```
=== Git log scan: "sbp_" (0 diff lines) ===
=== Git log scan: "SECRET_KEY" (0 diff lines) ===
=== Git log scan: "DATABASE_URL" (0 diff lines) ===
=== Git log scan: "service_role" (4166 diff lines) ===
  (Hanya berupa komentar SQL dan pengecekan hak akses internal auth.role() = 'service_role')
```

1.6 Supabase Row Level Security (RLS) Live Probing (Anon Role)

Pengujian pembacaan dan penulisan langsung menggunakan Anon Key ke live Supabase:

```
=== SUPABASE LIVE RLS AUDIT (ANON ROLE / UNAUTHENTICATED) ===
1. SELECT profiles: HTTP 200 -> Rows: 0 (Akses data pengguna lain diblokir RLS)
2. SELECT transactions: HTTP 200 -> Rows: 0 (Akses transaksi pengguna lain diblokir RLS)
3. SELECT payment_mutations: HTTP 200 -> Rows: 0 (Akses mutasi diblokir RLS)
4. INSERT profiles (Eskalasi Role 'admin'): HTTP 401 ->
   {"code":"42501","message":"new row violates row-level security policy for table \"profiles\""} (DITOLAK)
```

```
5. INSERT transactions (Pemalsuan Transaksi 'paid'): HTTP 401 ->
   {"code":"42501","message":"new row violates row-level security policy for table \"transactions\""} (DITOLAK)
```

1.7 Hasil Pengujian Unit Baru (64/64 Unit Tests PASS)

Seluruh 64 skenario pengujian unit (termasuk 24 tes baru untuk fallback displayName, pemetaan error translateAuthError, QRIS edge cases 0 / negatif / besar / rusak, dan validasi berkas upload) lulus 100%:

```
PS C:\Users\Administrator\Documents\digiq> flutter test --coverage
00:20 +36: test/audit_hardening_test.dart: ProfileModel.displayName fallback ke 'User'
00:20 +37: test/audit_hardening_test.dart: AuthService.translateAuthError mapping upstream timeout
00:20 +38: test/audit_hardening_test.dart: AuthService.translateAuthError mapping Database error saving new user
00:20 +43: test/audit_hardening_test.dart: QRIS nominal 0 menghasilkan tag 54 dan CRC valid
00:20 +44: test/audit_hardening_test.dart: QRIS nominal 999.999.999 menghasilkan tag 540999999999 dan CRC valid
00:20 +45: test/audit_hardening_test.dart: QRIS nominal negatif menghasilkan CRC valid
00:20 +46: test/audit_hardening_test.dart: QRIS verifyCrc16 menolak payload yang rusak atau dipotong
00:20 +48: test/audit_hardening_test.dart: Validasi gambar meloloskan JPEG dan PNG valid
00:20 +50: test/audit_hardening_test.dart: Validasi gambar menolak berkas > 2MB
00:20 +51: test/audit_hardening_test.dart: Validasi gambar menolak exploit SVG XSS & executable
00:20 +52: test/audit_hardening_test.dart: Validasi gambar menolak file EXE yang di-rename ke .jpg
...
00:41 +64: All tests passed!
```

1.8 Cakupan Kode Unit Test (Coverage Report)

Line coverage meningkat dari 37.26% menjadi **45.05%**:

```
================================================
           DIGIQ CODE COVERAGE REPORT
================================================
Total Source Lines Evaluated : 424
Total Lines Covered (Hit)    : 191
Unit Test Line Coverage      : 45.05%

Files Analyzed:
  • lib\models\payment_mutation_model.dart            :  18/34  ( 52.9%)
  • lib\models\profile_model.dart                     :   6/31  ( 19.4%)
  • lib\models\transaction_model.dart                 :  26/45  ( 57.8%)
  • lib\services\auth_service.dart                    :  43/166 ( 25.9%)
  • lib\services\deep_link_auth_handler.dart          :   0/23  (  0.0%)
  • lib\services\qris_service.dart                    :  98/111 ( 88.3%)
  • lib\services\supabase_config.dart                 :   0/14  (  0.0%)
================================================
```

1.9 Static Code Analysis Seluruh Proyek (`flutter analyze .`)

Pengujian analisis statis terhadap **seluruh direktori proyek** (bukan hanya `lib/`):

```
PS C:\Users\Administrator\Documents\digiq> flutter analyze .
Analyzing digiq...
```

```
No issues found! (ran in 5.3s)
```

1.10 Klarifikasi Hasil `flutter pub outdated`

Tidak ada kontradiksi teknis:

Direct Dependencies: `all up-to-date` (Semua package yang dideklarasikan langsung di `pubspec.yaml` berada pada versi terbarunya).
Dev Dependencies: `all up-to-date`.
Transitive Dependencies (5 dependencies): `jni`, `material_color_utilities`, `meta`, `shared_preferences_android`, dan `vector_math` terkunci pada `pubspec.lock` karena ditarik oleh dependensi tingkat kedua. Versi tersebut dapat diperbarui dengan menjalankan `flutter pub upgrade` tanpa mengubah deklarasi `pubspec.yaml`.

BAGIAN 2: NOT VERIFIED (MEMBUTUHKAN AKSI PENGGUNA / LIVE DB)

Item pada bagian ini **belum dapat ditandai PASS** karena membutuhkan persetujuan dan eksekusi langsung oleh pemilik proyek pada database Supabase live:

1. **Aplikasi Migrasi Database `006_username_and_registration_hardening.sql` (NOT VERIFIED):**

Status Saat Ini: Kolom `username` belum ada di tabel `profiles` live, dan pemanggilan RPC `check_username_available` menghasilkan HTTP 404.
Aksi yang Dibutuhkan: Pengguna harus membuka Supabase SQL Editor (`https://supabase.com/dashboard/project/iqxoofrhhrqkgehuvrlb/sql`), lalu menyalin dan menjalankan seluruh isi file `supabase/006_username_and_registration_hardening.sql`.

2. **Pendaftaran Akun Baru End-to-End dengan Email Nyata (NOT VERIFIED):**

Status Saat Ini: Simulasi penanganan timeout dan validasi username di sisi frontend telah diverifikasi lulus tes, namun pengujian pengiriman email verifikasi OTP nyata bergantung pada ketersediaan provider SMTP pada dashboard Supabase.
Aksi yang Dibutuhkan: Setelah migrasi 006 diaplikasikan, lakukan pendaftaran akun pengujian melalui antarmuka web di `https://enikzrad.web.id/register`.

3. **Penerapan Konfigurasi Storage Bucket Constraints di Supabase (NOT VERIFIED):**

Status Saat Ini: Skrip SQL 006 menyertakan perintah pembaruan tabel `storage.buckets` (`file_size_limit = 2097152`), namun batasan ini baru aktif setelah skrip dieksekusi di database live.

BAGIAN 3: REKOMENDASI TEKNIS & OPERASIONAL

Berikut adalah langkah-langkah terurut yang disarankan:

Rekomendasi 1: Terapkan Migrasi 006 di Supabase SQL Editor

Salin file `supabase/006_username_and_registration_hardening.sql` ke Supabase SQL Editor. Jalankan verifikasi query berikut:

```
SELECT column_name, is_nullable FROM information_schema.columns
WHERE table_name = 'profiles' AND column_name = 'username';
-- Hasil harus: is_nullable = 'NO'

SELECT public.check_username_available('testuser123');
-- Hasil harus: true
```

Rekomendasi 2: Daftarkan `spa_server.py` sebagai Windows Service Permanen

Agar web server tidak berhenti jika terminal ditutup atau komputer me-restart:

Gunakan utilitas NSSM (Non-Sucking Service Manager) atau Windows Task Scheduler untuk menjalankan skrip PowerShell:

```
powershell -ExecutionPolicy Bypass -File C:\Users\Administrator\Documents\digiq\scripts\serve_prod_9000.ps1
```

Rekomendasi 3: Hapus Rule Firewall Port 9000 yang Tidak Diperlukan

Karena traffic publik sepenuhnya ditangani oleh `cloudflared.exe` melalui koneksi tunnel keluar (outbound), tidak diperlukan membuka port 9000 ke jaringan publik pada Windows Firewall:

```
Remove-NetFirewallRule -DisplayName "DigiQ Web Port 9000" -ErrorAction SilentlyContinue
```

Rekomendasi 4: Konfigurasi Custom SMTP di Supabase Dashboard

Karena `mailer_autoconfirm: false`, GoTrue Auth akan menunggu respon SMTP sebelum menyelesaikan proses signup. Disarankan mengonfigurasi provider SMTP kustom bereputasi tinggi (Resend, AWS SES, atau Postmark) pada menu **Project Settings -> Authentication -> SMTP Settings** untuk mencegah latency di atas 5 detik.